CASE STUDY

The Dell RecoverPoint for Virtual Machines Hard-Coded Credential Zero-Day of 2026 (CVE-2026-22769): A Case Study

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

The people who carry this one are the backup, replication and virtualization teams. Dell RecoverPoint for Virtual Machines (RP4VMs) protects VMware workloads, so it sits deep inside the network, close to vCenter and ESXi. On 17 February 2026 Dell told those teams that the appliance shipped with a hard-coded credential, and that an unauthenticated remote attacker who knew it could reach the underlying operating system and keep root-level persistence [1] (**Confirmed**). Dell rated it Critical, CVSS 3.1 10.0, and said Google and Mandiant had reported limited active exploitation [1] (**Confirmed**).

Google Threat Intelligence Group (GTIG) and Mandiant published the intrusion record the same day. They found the flaw while responding to RP4VMs appliances in a victim environment that already had live BRICKSTORM and GRIMBOLT command and control, and they date the earliest exploitation they identified to mid-2024 [6] (**Reported**). GTIG attributes the activity to UNC6201, a suspected PRC-nexus cluster that overlaps with UNC5221 but that GTIG does not currently treat as the same cluster [6] (**Reported**). CISA added the CVE to the Known Exploited Vulnerabilities (KEV) catalog on 18 February with a three-day deadline [5] (**Confirmed**).

Key facts at a glance

Field	Value
Product	Dell RecoverPoint for Virtual Machines (RP4VMs); RecoverPoint Classic is not affected [1]
Flaw	Hard-coded credential; CWE-798 Use of Hard-coded Credentials [1] [3] [4]
Score	CVSS 3.1 10.0, AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H, from both Dell (CNA) and NVD [3] [4]
Root cause named by the discoverer	Hard-coded default credentials for the Apache Tomcat Manager admin user [6] (**Reported**)
Affected	Versions before 6.0.3.1 HF1: 5.3 SP4 P1, 6.0, 6.0 SP1, 6.0 SP1 P1, 6.0 SP1 P2, 6.0 SP2, 6.0 SP2 P1, 6.0 SP3, 6.0 SP3 P1; 5.3 SP4, SP3, SP2 and potentially earlier also impacted [1]
Fix	Upgrade to 6.0.3.1 HF1 (5.3 SP4 P1 first migrates to 6.0 SP3), or apply the remediation script in KB 000426742 [1] [2]
Advisory	DSA-2026-079 (KB 000426773), v1.0, 17 Feb 2026 [1]
CVE	Reserved by Dell 9 Jan 2026; published 17 Feb 2026 19:19 UTC [3]
Earliest exploitation identified	Mid-2024 [6] (**Reported**)
KEV	Added 18 Feb 2026, due 21 Feb 2026; ransomware use Unknown [5]
CISA SSVC (19 Feb 2026)	Exploitation active; automatable yes; technical impact total [3] [4]
Named actor	UNC6201, suspected PRC-nexus (GTIG) [6] (**Reported**)
Malware	SLAYSTYLE web shell, BRICKSTORM (S9015), GRIMBOLT [6] [9]
Credit	Peter Ukhanov, Google/Mandiant [1]

Key findings

- **A zero-day for about twenty months.** GTIG's earliest identified exploitation is mid-2024 [6] (**Reported**), and the advisory and CVE arrived on 17 February 2026 [1] [3] (**Confirmed**). That gap is roughly nineteen to twenty months of use before a vendor fix existed (**Inferred** from the two dates).
- **The bug is a password, not a code path.** Dell describes a hard-coded credential and does not name the component [1] (**Confirmed**). GTIG names the Apache Tomcat Manager admin user [6] (**Reported**), and Dell's remediation script rotates the Tomcat admin credential and restricts the Manager to localhost [2] (**Confirmed**), which is consistent with GTIG's account (**Inferred**).
- **The appliance was a foothold, not necessarily the front door.** GTIG says UNC6201 used the flaw to move laterally, persist and deploy malware, and that the initial access vector into the networks was not confirmed [6] (**Reported**).
- **Patching does not evict.** The flaw grants root-level persistence [1] (**Confirmed**), and the actor modified a boot-time script and swapped its backdoor in September 2025 [6] (**Reported**). An appliance patched today can still carry an implant from 2024 (**Inferred**).

- **Scale is not in the record.** GTIG gives no victim count, sector or geography, and Dell says "limited active exploitation" [1] [6] (**Confirmed** for Dell; GTIG **Reported**).
- **The record has small defects.** Dell's advisory cites "CVE-2026-22796" in its RecoverPoint Classic note and has one CVSS link that points to a different, local vector [1] (**Confirmed** as observed); the first is an apparent typo, not a second CVE (**Inferred**).

Top recommendations

1. Upgrade every RP4VMs appliance to 6.0.3.1 HF1, or run the KB 000426742 script on each one, and rerun the script on any appliance that is reimaged or newly added [1] [2] (**Confirmed** as vendor guidance).
2. Put RP4VMs on a trusted, access-controlled, segmented internal network, as Dell advises [1] (**Confirmed**).
3. Hunt before and after patching: Tomcat Manager audit and application logs for deploy activity, WAR files and cache artifacts in the web-application directories, boot-script integrity, unexpected DNS-over-HTTPS, and GTIG's YARA rules for GRIMBOLT and SLAYSTYLE [6] (**Reported**).
4. Extend the hunt to the VMware estate the appliance touches: unexpected network interfaces on ESXi-hosted virtual machines, and iptables rules on vCenter appliances that do not match the build [6] (**Reported**).
5. Count backup and replication appliances as tier-0 assets in scanning and KEV tracking. CISA's three-day deadline and its SSVC decision of automatable and total technical impact put this flaw in the same class as an internet-facing VPN [3] [5] (**Inferred**).

Scope and method

This brief covers CVE-2026-22769 from the earliest exploitation GTIG identifies (mid-2024) through the record as it stood on 11 November 2026, with GTIG's September 2025 BRICKSTORM report and the CISA, NSA and Canadian Cyber Centre BRICKSTORM analysis report as lineage. It does not repeat the China-nexus history in Threat Actors: China. Tradecraft is described at advisory level; no exploit steps, credential values, indicator values or payloads are reproduced.

Grade	Meaning in this study
Confirmed	Stated in a primary opened for this study: Dell's advisory and knowledge-base article, the CVE, NVD and KEV records, the CISA, NSA and Cyber Centre report, the ATT&CK page, the Intelligence Hub data and the library's own files
Reported	Stated by a named research firm (Google Threat Intelligence Group and Mandiant) and not confirmed in a vendor or government primary
Demonstrated	A research proof of concept or a fixed flaw with no known in-the-wild use; no claim in this study carries this grade
Inferred	This study's own reasoning from cited facts, labelled where it appears

All sources were opened on 11 November 2026. GTIG is the discoverer and Dell credits it [1], but its intrusion detail is graded Reported unless Dell, CISA or NVD states the same thing. The research went straight to the

known primaries, and nothing beyond the sources listed below was checked. The CISA alert page for the 18 February KEV addition could not be opened; the KEV catalog itself is cited instead. No regulator filing, named victim statement or news report was searched for; that ground is not checked, and none appears in the sources that were opened.

Part 1: what happened

Date	Event	Sources	Grade
Mid-2024	Earliest exploitation of the flaw that GTIG identifies; UNC6201 uses it to move laterally, persist and deploy SLAYSTYLE, BRICKSTORM and GRIMBOLT	[6]	Reported
Sep 2025	Mandiant sees older BRICKSTORM binaries on compromised appliances replaced with GRIMBOLT; GTIG cannot say whether this was planned or a reaction to incident response	[6]	Reported
24 Sep 2025	GTIG publishes its BRICKSTORM espionage campaign report on UNC5221 and related clusters; it does not mention RecoverPoint or Dell	[7]	Reported
4 Dec 2025	CISA, NSA and the Canadian Cyber Centre publish AR25-338A, BRICKSTORM Backdoor; revised 5 Dec	[8]	Confirmed
19 Dec 2025	AR25-338A revised to add Rust samples	[8]	Confirmed
9 Jan 2026	Dell reserves CVE-2026-22769	[3]	Confirmed
20 Jan 2026	AR25-338A revised to add YARA rules	[8]	Confirmed
11 Feb 2026	AR25-338A revised to add Sample 12, a .NET native AOT BRICKSTORM variant whose SHA256 GTIG later lists as GRIMBOLT	[8] [6]	Confirmed
17 Feb 2026	Dell publishes DSA-2026-079 v1.0; CVE datePublic 18:00 UTC, record published 19:19 UTC; NVD publishes 20:22 UTC; GTIG publishes its UNC6201 report	[1] [3] [4] [6]	Confirmed; GTIG content Reported
18 Feb 2026	CISA adds the CVE to KEV, due 21 Feb; the Intelligence Hub records the addition	[5] [10]	Confirmed
19 Feb 2026	CISA SSVC decision: exploitation active, automatable yes, technical impact total	[3] [4]	Confirmed
18 Mar 2026	Dell KB 000426742 (remediation script) revised to version 2	[2]	Confirmed
16 Apr 2026	ATT&CK creates S9015 BRICKSTORM, naming UNC6201 among its users and citing the GTIG RecoverPoint report	[9]	Confirmed
17 Jun 2026	NVD record last modified; status Analyzed	[4]	Confirmed

Discrepancies in the record

- **Who named the component.** Dell does not name it [1]; GTIG names the Tomcat Manager admin user [6]; the knowledge-base script matches GTIG's account [2] (**Inferred**).
- **The second CVE number.** "CVE-2026-22796" appears only in Dell's RecoverPoint Classic note [1] (**Confirmed** as observed). With no other source using it, this study reads it as a transposition of CVE-2026-22769 (**Inferred**).
- **The CVSS link.** One CVSS link on Dell's page points to a local vector rather than the network vector the advisory and NVD both record [1] [4] (**Confirmed** as observed). The scored vector in the CVE and NVD records is the network one [3] [4] (**Confirmed**).
- **GRIMBOLT and AR25-338A Sample 12 are the same file.** CISA's 11 February revision adds Sample 12, a file named support that it calls a .NET native AOT variant of BRICKSTORM [8]. Six days later GTIG lists a GRIMBOLT file named support with the identical SHA256 [6] (**Confirmed**: same hash in both sources; this study does not reproduce it). CISA filed the sample under BRICKSTORM and GTIG gave it a new name. Neither source mentions the other's name, so the two agencies label one binary differently (**Inferred**).

Part 2: the intrusion record

The flaw, at advisory level. RP4VMs shipped with a credential built into the product. Per Dell, an unauthenticated remote attacker who knows it can reach the underlying operating system and gain root-level persistence [1] (**Confirmed**). Per GTIG, the credential belonged to the Apache Tomcat Manager admin user; with it, the actor deployed a malicious web application archive (WAR) containing the SLAYSTYLE web shell and ran commands as root [6] (**Reported**). Nothing about this needs a memory-corruption chain: anyone holding the value and a network path to the Manager had the box (**Inferred**).

What was found on the appliances. GTIG lists three families [6] (**Reported**):

- **SLAYSTYLE**, a JSP web shell, delivered in the WAR through Tomcat Manager. GTIG's 2025 report says MITRE tracks SLAYSTYLE as BEEFLUSH [7] (**Reported**); the library's ATT&CK v20.0 software data has no BEEFLUSH object [11] (**Confirmed**).
- **BRICKSTORM**, the backdoor GTIG, CISA, NSA and the Cyber Centre have tracked since 2025 [7] [8], and which ATT&CK records as S9015 [9] (**Confirmed** for the ATT&CK object).
- **GRIMBOLT**, a new C# backdoor compiled with Native AOT and packed with UPX, giving a remote shell and using the same command-and-control infrastructure as BRICKSTORM. Mandiant saw it replace BRICKSTORM binaries from September 2025 [6] (**Reported**).

Persistence. The actor modified a legitimate boot-time shell script run through rc.local, so its implant came back on every reboot [6] (**Reported**).

Reaching beyond the appliance. In VMware environments GTIG saw the actor add temporary network interfaces, which it calls "Ghost NICs", to virtual machines on ESXi hosts in order to pivot into internal and SaaS environments, and use iptables-based single packet authorization on compromised vCenter appliances to hide a backdoor port [6] (**Reported**). Both moves live in the hypervisor and management layer, where endpoint agents usually do not run (**Inferred**).

How it was found. Mandiant found the flaw while investigating several RP4VMs appliances in a victim environment that had active BRICKSTORM and GRIMBOLT command and control [6] (**Reported**), and Dell credits Peter Ukhanov of Google/Mandiant [1] (**Confirmed**).

What GTIG published for defenders. Detection guidance (summarized in Part 5), Google SecOps rules, YARA rules for GRIMBOLT and SLAYSTYLE, and indicators (file hashes, one command-and-control IP address and one WebSocket endpoint) [6] (**Reported**). This study does not reproduce the indicator values. The report names no ATT&CK technique ids [6] (**Confirmed** by absence on the page).

Part 3: who and why

The attribution, exactly as stated. GTIG attributes the exploitation to UNC6201, which it calls a *suspected* PRC-nexus threat cluster. It notes notable overlaps with UNC5221, a name GTIG says has been used synonymously with the actor publicly reported as Silk Typhoon, and it says it does not currently consider UNC6201 and UNC5221 the same cluster [6] (**Reported**). Dell's advisory names no actor [1] (**Confirmed**). Any reading that calls this a Silk Typhoon or HAFNIUM operation goes further than the discoverer does (**Inferred**).

What ATT&CK records. ATT&CK's S9015 BRICKSTORM entry, created 16 April 2026, lists UNC6201 among the PRC state-nexus actors that use the backdoor and cites the GTIG RecoverPoint report [9] (**Confirmed**). ATT&CK has no group object for UNC6201 and no software object for GRIMBOLT [9] [11] (**Confirmed**). Its HAFNIUM group (G0125) carries the alias Silk Typhoon, and its Cutting Edge campaign (C0029) names UNC5221 among the suspected China-nexus actors behind the 2023 to 2024 Ivanti Connect Secure exploitation [11] (**Confirmed**). Neither object mentions RecoverPoint, and this study treats both as lineage only (**Inferred**).

The BRICKSTORM lineage. GTIG's September 2025 report ties BRICKSTORM to UNC5221 and related suspected China-nexus clusters that went after legal, SaaS, business process outsourcing and technology organizations, pivoted from edge appliances into VMware vCenter and ESXi, and stayed an average of 393 days before detection [7] (**Reported**). The CISA, NSA and Cyber Centre report attributes BRICKSTORM to PRC state-sponsored actors with victims primarily in the Government Services and Facilities and the Information Technology sectors [8] (**Confirmed**). Neither report mentions RecoverPoint, CVE-2026-22769, GRIMBOLT or UNC6201 by name [7] [8], although AR25-338A's Sample 12 carries the hash GTIG gives for GRIMBOLT [6] [8] (**Confirmed**).

Why a backup appliance. None of the sources states the actor's intent beyond espionage tradecraft. Read against the BRICKSTORM record of long dwell on infrastructure that defenders rarely inspect [7] [8], a replication appliance with root access, a view into vCenter and no endpoint agent is a natural long-term perch (**Inferred**). Threat Actors: China covers the naming disputes around UNC5221 and Silk Typhoon in depth [12] (**Confirmed**).

Part 4: impact and response

Victims. The record gives no count, sector or geography. GTIG describes incident response engagements, including the victim environment in which Mandiant found the flaw, and exploitation since mid-2024 [6] (**Reported**); Dell calls it "limited active exploitation" reported by Google/Mandiant [1] (**Confirmed**). No victim statement, regulator filing or ransomware use appears in any source opened; KEV marks ransomware use as Unknown [5] (**Confirmed**).

The vendor. Dell published DSA-2026-079 v1.0 on 17 February with two paths: upgrade to 6.0.3.1 HF1 or apply the remediation script [1] (**Confirmed**). The script, in KB 000426742, rotates the Tomcat admin credential to a random value and restricts Tomcat Manager to localhost; it needs no reboot and must be rerun on reimaged or newly added appliances. Dell revised the article to version 2 on 18 March [2] (**Confirmed**). Dell also advises running RP4VMs only on a trusted, access-controlled internal network [1] (**Confirmed**).

CVE and NVD. Dell, as CNA, assigned CWE-798 and CVSS 10.0 [3]; NVD agreed on both and marks the record Analyzed [4] (**Confirmed**). Part 1 carries the dates.

CISA. CISA added the CVE to KEV on 18 February with a due date of 21 February, three days [5] (**Confirmed**). Its SSVC decision on 19 February recorded active exploitation, automatable yes and total technical impact [3] [4] (**Confirmed**). The Team Star Wolf Intelligence Hub carries the KEV row kev-CVE-2026-22769, dated 18 February with CVSS 10 and CWE-798 [10] (**Confirmed**).

Part 5: the defender and vulnerability-management view

Backup and replication appliances are usually managed by a different team from the one that runs edge security, and they are often missing from both the vulnerability scanner's scope and the endpoint agent's install base (**Inferred**). This record shows why that matters: the flaw sat in an admin interface on an appliance with root access next to vCenter, and GTIG records the actor using it to move laterally and persist, while the way into the networks was not confirmed [6] (**Reported**).

Control	Where it meets the record
Upgrade to 6.0.3.1 HF1 or run the KB 000426742 script on every appliance, including reimaged and new ones	Vendor fix paths [1] [2]
Restrict network reach to the appliance and its management interfaces	Dell's segmentation advice; the script limits Manager to localhost [1] [2]
Review Tomcat Manager audit and application logs for deploy activity	GTIG detection guidance [6]
Inspect web-application and cache directories for unexpected WAR artifacts	GTIG detection guidance [6]
Check boot-script integrity against a known-good build	rc.local persistence [6]
Alert on new or temporary network interfaces on ESXi-hosted virtual machines	Ghost NICs [6]
Audit iptables rules on vCenter appliances	Single packet authorization hiding a backdoor port [6]

Control	Where it meets the record
Watch egress for unexpected DNS-over-HTTPS and WebSocket traffic from infrastructure hosts	GTIG detection guidance and indicator types [6]
Treat any KEV entry with "automatable" and "total" as an emergency, wherever the asset sits	SSVC decision and three-day KEV deadline [3] [5]

For prioritization, this CVE carries every signal a risk model can carry: CVSS 10.0, KEV with a three-day deadline, and an SSVC decision of active, automatable and total [3] [4] [5] (**Confirmed**). The gap was never in the scoring. It was in whether the appliance was on the list at all (**Inferred**). The Vulnerability Prioritization Reference and Vulnerability Management Reference cover the inventory side.

What is overstated and what is understated

- **Overstated:** any "mass exploitation" framing. Dell says limited, GTIG describes espionage activity found across its incident response engagements, without a count, and KEV ransomware use is Unknown [1] [5] [6] (**Confirmed** and **Reported**). Calling this a Silk Typhoon or HAFNIUM operation also overstates the record: GTIG names UNC6201, calls it suspected PRC-nexus, and says it does not currently consider UNC6201 and UNC5221 the same cluster [6] (**Reported**).
- **Understated:** dwell time and the limits of the patch. Exploitation from mid-2024 [6] means roughly nineteen to twenty months as a zero-day (**Inferred**), and the flaw grants root-level persistence [1] (**Confirmed**). An upgrade or a credential rotation closes the door but does not remove an implant already in a boot script (**Inferred**). With no victim count published, the engagements GTIG describes are a floor, not a measure of reach (**Inferred**).

MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0 Enterprise, CWE, CAPEC and D3FEND. Names and tactics come from the library's `data/attack/technique_profiles.jsonl`, `superseded_by.jsonl`, `groups.jsonl`, `software.jsonl`, `campaigns.jsonl` and `technique_to_d3fend.jsonl`, and from `data/weaknesses/` [11] (**Confirmed**). GTIG names no ATT&CK technique ids [6], so each row below is this study's own mapping (**Inferred**). None of the bound ids is revoked [11] (**Confirmed**). RP4VMs, vCenter and ESXi are IT infrastructure and no source describes an industrial effect, so no ATT&CK for ICS table applies.

Groups, software and campaigns

Object	ATT&CK id	Relationship to this record
BRICKSTORM	S9015	Deployed on compromised RP4VMs appliances, later replaced by GRIMBOLT (GTIG, 17 Feb 2026) [6]; ATT&CK names UNC6201 among its users (16 Apr 2026) [9]
HAFNIUM	G0125	Lineage only: ATT&CK's group carrying the Silk Typhoon alias [11], the name GTIG says is used for UNC5221; GTIG does not currently treat UNC6201 and UNC5221 as the same cluster [6]
Cutting Edge	C0029	Lineage only: ATT&CK campaign naming UNC5221 among the actors behind Ivanti Connect Secure exploitation (Dec 2023 to Feb 2024) [11]; no tie to RecoverPoint

ATT&CK has no group object for UNC6201 and no software object for GRIMBOLT or for SLAYSTYLE under its BEEFLUSH name [9] [11] (**Confirmed**).

ATT&CK Enterprise techniques

ID	Name	Tactic(s)	Dated event or report	Sources
T1078.001	Default Accounts	Initial Access, Persistence, Privilege Escalation, Stealth	Hard-coded credential (DSA-2026-079, 17 Feb 2026); the Tomcat Manager admin user (GTIG, 17 Feb 2026); KEV 18 Feb 2026	[1] [5] [6]
T1505.003	Web Shell	Persistence	SLAYSTYLE JSP web shell in a malicious WAR deployed through Tomcat Manager (GTIG, 17 Feb 2026)	[6]
T1059.004	Unix Shell	Execution	Commands run as root on the appliance; GRIMBOLT remote shell (GTIG, 17 Feb 2026)	[6]
T1037.004	RC Scripts	Persistence, Privilege Escalation	Legitimate boot-time script run through rc.local modified (GTIG, 17 Feb 2026)	[6]
T1105	Ingress Tool Transfer	Command and Control	BRICKSTORM deployed, then replaced by GRIMBOLT from Sep 2025 (GTIG, 17 Feb 2026)	[6]
T1027.002	Software Packing	Stealth	GRIMBOLT packed with UPX (GTIG, 17 Feb 2026)	[6]
T1205.001	Port Knocking	Stealth, Persistence, Command and Control	iptables-based single packet authorization hiding a backdoor port on vCenter (GTIG, 17 Feb 2026)	[6]
T1071.001	Web Protocols	Command and Control	A WebSocket (wss) endpoint among the published indicators (GTIG, 17 Feb 2026)	[6]

Fit notes (**Inferred**): T1078.001 is the closest fit for a credential the vendor ships in every unit; T1190 is not bound because the weakness is a credential rather than a software defect, and GTIG says the flaw served lateral movement and persistence while initial access to the networks was not confirmed [6]. T1059.004 assumes the root commands ran through the appliance's Linux shell, which GTIG implies but does not spell out; ATT&CK maps BRICKSTORM to the same technique [11]. T1205.001 binds single packet authorization as a one-packet form of the port knocking ATT&CK describes. T1071.001 is an inexact fit, inferred from the indicator type alone. Not bound: the Ghost NICs, because ATT&CK has no technique for adding virtual interfaces to guest machines and the nearest, T1599 Network Boundary Bridging, covers network devices only [11]; the iptables change as T1686 Disable or Modify System Firewall, because the rules hid a port rather than weakening the firewall; and DNS-over-HTTPS, which ATT&CK records for BRICKSTORM under T1071.004 [9] but which GTIG's RecoverPoint report names only in its detection rules [6], so it is not bound to this appliance record. The other techniques ATT&CK lists for S9015 are not repeated here because the RecoverPoint record does not describe them [9].

CWE and CAPEC

CWE	Name	Where it is assigned	Sources
CWE-798	Use of Hard-coded Credentials	CVE-2026-22769 (CNA, NVD Primary, KEV)	[3] [4] [5]

CAPEC	Name	Via	Where it meets the record
CAPEC-70	Try Common or Default Usernames and Passwords	The library relates it to CWE-798 [11]	Use of the shipped Tomcat Manager credential [6]
CAPEC-191	Read Sensitive Constants Within an Executable	The library relates it to CWE-798 [11]	How a hard-coded value is usually recovered; no source says how UNC6201 obtained it (**Inferred**)

See the CWE Reference and CAPEC Reference.

D3FEND countermeasures

D3FEND countermeasure	Techniques the library maps it to (from this study)	Where it meets the record
Change Default Password	T1078.001	The remediation script sets a random Tomcat admin credential [2]
File Integrity Monitoring	T1505.003, T1037.004, T1027.002	WAR artifacts and the modified boot script [6]
System Init Config Analysis	T1037.004	The rc.local boot-script persistence [6]
File Analysis	T1505.003, T1027.002	GTIG's YARA rules for GRIMBOLT and SLAYSTYLE [6]
Restore Configuration	T1037.004	Returning boot scripts to a known-good build [6]
Network Traffic Filtering	T1205.001, T1105, T1071.001	Segmenting the appliance and vCenter, as Dell advises [1] [6]
Outbound Traffic Filtering	T1105, T1071.001	Command-and-control egress from infrastructure hosts [6]

Dell's main fix, the 6.0.3.1 HF1 upgrade, corresponds to Software Update, and restricting the Manager to localhost resembles Inbound Traffic Filtering; the library does not relate either to the techniques bound here [11] (**Inferred**). See the D3FEND Reference.

Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, `navigator/library-layers/dell-recoverpoint-cve-2026-22769.json` (open in Navigator). Scores: 75 for behavior in a vendor advisory, the KEV record or a government advisory, 50 for a vendor threat-intelligence report, 25 for an inexact fit. Each technique's comment names its source numbers.

Cross-cutting themes

- **Infrastructure appliances are edge devices with no edge.** BRICKSTORM's story, from GTIG in 2025 to CISA's report to this CVE, is about appliances and hypervisors that defenders do not instrument [6] [7] [8]. The Edge Device Security Reference traces the same pattern on VPNs and firewalls (**Inferred**).
- **Shipped credentials outlive every patch cycle.** A hard-coded credential is the same in every unit until the vendor changes it, which is why one value could serve an actor from mid-2024 to February 2026 [1] [6] (**Inferred**). Apache Tomcat's own interfaces have been an exposure before: Ghostcat (CVE-2020-1938)

covers the default-on AJP connector, a different component from the Manager (**Inferred**). The library's ICS attacks and advisories and Stuxnet studies trace the same default and hard-coded credential pattern in industrial systems (**Inferred**).

- **Patch, then hunt.** Root-level persistence in a boot script [6] means remediation has two halves: the fix and an integrity check. KEV deadlines measure only the first (**Inferred**).
- **Attribution is a set of overlapping clusters.** UNC6201, UNC5221, Silk Typhoon and HAFNIUM overlap without being one actor in the sources [6] [11]. The library's Exchange Marauder 2021 study shows how HAFNIUM was first named, and Threat Actors: China tracks the later naming (**Inferred**).

Sources

All sources were opened on 11 November 2026. Addresses shown as code rather than as links refuse automated link checkers (the dell.com support articles); copy them into a browser to open them.

#	Source	URL	Opened	Grade
1	Dell, Security Advisory DSA-2026-079 for RecoverPoint for Virtual Machines, KB 000426773, v1.0, 17 Feb 2026	`https://www.dell.com/support/kbdoc/en-us/000426773/dsa-2026-079`	2026-11-11	Confirmed
2	Dell, RecoverPoint for VMs: Apply the Remediation Script for DSA, KB 000426742, version 2, 18 Mar 2026	`https://www.dell.com/support/kbdoc/en-us/000426742/recoverpoint-for-vms-apply-the-remediation-script-for-dsa`	2026-11-11	Confirmed
3	CVE Program record CVE-2026-22769 (CNA Dell, with the CISA-ADP container), read through the CVE Services API, record last updated 2026-02-26	cveawg.mitre.org/api/cve/CVE-2026-22769 (also shown at cve.org/CVERecord?id=CVE-2026-22769)	2026-11-11	Confirmed
4	NVD, CVE-2026-22769 (page and API record)	nvd.nist.gov/vuln/detail/CVE-2026-22769	2026-11-11	Confirmed
5	CISA, Known Exploited Vulnerabilities catalog JSON, entry CVE-2026-22769	cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-11	Confirmed
6	Google Threat Intelligence Group and Mandiant (authors include Peter Ukhanov), From BRICKSTORM to GRIMBOLT: UNC6201 Exploiting a Dell RecoverPoint for Virtual Machines Zero-Day, 17 Feb 2026	cloud.google.com/blog/topics/threat-intelligence/unc6201-exploiting-dell-recoverpoint-zero-day	2026-11-11	Reported
7	Google Threat Intelligence Group, BRICKSTORM espionage campaign, 24 Sep 2025	cloud.google.com/blog/topics/threat-intelligence/brickstorm-espionage-campaign	2026-11-11	Reported
8	CISA, NSA and Canadian Centre for Cyber Security, AR25-338A BRICKSTORM Backdoor, 4 Dec 2025, revised to 11 Feb 2026	cisa.gov/news-events/analysis-reports/ar25-338a	2026-11-11	Confirmed
9	MITRE ATT&CK, S9015 BRICKSTORM, created 16 Apr 2026	attack.mitre.org/software/S9015/	2026-11-11	Confirmed
10	Team Star Wolf Intelligence Hub, feed.json (KEV row kev-CVE-2026-22769)	teamstarwolf.github.io/intelligence-hub/data/feed.json	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
11	TeamStarWolf library data: `data/attack/technique_profiles.jsonl`, `superseded_by.jsonl`, `groups.jsonl`, `software.jsonl`, `software_to_technique.jsonl`, `campaigns.jsonl`, `technique_to_d3fend.jsonl` (ATT&CK v20.0), `data/weaknesses/cwe.jsonl` and `capec.jsonl`, and the `mitre/` tree	github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	2026-11-11	Confirmed
12	TeamStarWolf, Threat Actors: China	/case-studies/THREAT_ACTORS_CHINA.md	2026-11-11	Confirmed

Not opened, so not cited: the CISA alert page for the 18 February 2026 KEV addition (the address tried returned an error), the Google Threat Intelligence indicator collection, and any news coverage.

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Threat Actors: China, Ghostcat (CVE-2020-1938), Exchange Marauder 2021, ICS attacks and advisories 2024 to 2026, Stuxnet, The Year 2025 in Intrusions, The Year 2026 in Intrusions, Timeline
- Other 2026 studies with a suspected China-nexus or edge-appliance thread: The BeyondTrust Remote Support and PRA command injection, The Ivanti Connect Secure zero-day chain, The PAN-OS GlobalProtect authentication bypass, The Check Point Remote Access VPN IKEv1 authentication bypass, The Citrix NetScaler zero-days
- Threat Actors, Malware Families, Notable Incidents
- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Edge Device Security Reference, Hypervisor Security Reference, Dell PowerProtect, Vulnerability Management Reference, Vulnerability Prioritization Reference
- Groups: G0125 HAFNIUM (lineage only)
- Software: S9015 BRICKSTORM
- Campaigns: C0029 Cutting Edge (lineage only)
- Techniques: T1078.001 Default Accounts, T1505.003 Web Shell, T1059.004 Unix Shell, T1037.004 RC Scripts, T1105 Ingress Tool Transfer, T1027.002 Software Packing, T1205.001 Port Knocking, T1071.001 Web Protocols
- CAPEC: CAPEC-70, CAPEC-191

- Navigator layers, including this study's layer, dell-recoverpoint-cve-2026-22769.json
- The Team Star Wolf Intelligence Hub
- All case studies